

RAPPORT DE TRAVAUX PRATIQUES

Résolution du Google XSS Game — Laboratoire de Sécurité Web

Nom : DJIMEN NJO'SSEU JOEL MIGUEL

Niveau : Licence

Module : Sécurité des Applications Web / Réseaux et Cybersécurité

Objectif : Exploitation technique et compréhension des vulnérabilités Cross-Site Scripting (XSS)

Statut du Lab : Terminé avec succès (6/6 Niveaux)

1.Introduction

Ce document dresse le bilan technique du TP dédié à la découverte et au contournement des protections contre les failles **Cross-Site Scripting (XSS)** à travers la plateforme didactique *Google XSS Game*. L'objectif global était d'injecter du code JavaScript arbitraire afin de forcer l'exécution de la fonction `alert()` au sein des différents contextes applicatifs proposés. Cette série d'exercices a permis de mettre en pratique des concepts clés de l'analyse de vulnérabilités web, notamment la manipulation du DOM, la compréhension des types de XSS (réfléchi, stocké, basé sur le DOM) et l'analyse de filtres légers côté client et serveur.

2. Synthèse technique des résolutions

Le tableau ci-dessous résume la démarche logique, le type de vulnérabilité identifié et la charge utile

(payload) finale ayant permis de valider chacun des six niveaux de la plateforme.

Niveau	Type de XSS / Contexte	Charge utile (Payload) & Approche technique
Level 1 Hello, world	Reflected XSS Entrée brute dans le code HTML.	L'application reflétait directement la saisie utilisateur sans aucun nettoyage. Une balise de script classique s'exécute immédiatement. <script>alert(1)</script>
Level 2 Madchattr	Stored XSS Insertion dynamique (innerHTML).	Les balises <script> étant bloquées lors de l'insertion DOM via innerHTML, l'utilisation d'une balise d'image avec un déclencheur d'erreur a permis de contourner la restriction.
Level 3 Cloudy	DOM-based XSS Attribut HTML (src).	La valeur passée dans l'ancrage URL (hash) servait à construire une chaîne HTML. En utilisant un guillemet simple, l'attribut d'origine a été rompu pour injecter un gestionnaire d'événement. 1' onerror='alert(1)
Level 4 Timemer	Reflected XSS Contexte JavaScript interne.	L'entrée était injectée directement entre les guillemets d'une fonction JavaScript existante. Le payload ferme proprement la fonction, insère l'alerte, et gère la syntaxe résiduelle pour éviter un plantage du script. 3'); alert(1); ('
Level 5 Groovy	DOM-based XSS Attribut d'URL (href).	La valeur du paramètre next était intégrée dans l'attribut href d'un lien d'inscription. L'utilisation du pseudo-protocole javascript: a permis d'exécuter l'alerte au clic. javascript:alert(1)
Level 6 Gadget	DOM-based XSS Inclusion de script externe.	L'application chargeait un script via l'URL et bloquait les termes http/https. L'utilisation du schéma d'URI data: a permis d'embarquer directement le script en s'affranchissant d'un serveur tiers. data:text/javascript,alert(1)

[6/6] Niveau 6: Suivez le

Description de la mission

Les applications Web complexes ont parfois la capacité de charger dynamiquement Bibliothèques JavaScript en fonction de la valeur de leur URL paramètres ou partie de `location.hash`.

Ceci est très difficile à bien faire - permettant à l'utilisateur d'influencer l'URL lors du chargement de scripts ou d'autres types de données potentiellement dangereux tels que `XMLHttpRequest` Il en résulte souvent de graves vulnérabilités.

Objectif de la mission

Trouver un moyen de faire la demande de demande un fichier externe qui Il va le faire exécuter un `alert()`.

Bien joué ! Il est temps de débriefer >>

Votre cible

